

Threat Modeling Model Analysis Procedure

Revision

Version 2
2/21/25 3:20 PM

SME

Charles Wilson

Abstract

This document describes the procedure used to perform the threat model analysis activity described in the AVCDL secondary document **Threat Modeling Report** [\[2\]](#).

Group / Owner

Security / Security Architect

Motivation

This document is motivated by the need to identify design deficiencies related to cybersecurity as early in the product development process as possible. This is necessary given the nature of safety-critical, cyber-physical systems, subject to certifications such as **ISO/SAE 21434** and **ISO 26262**.

Note: Within the context of this document, the terms ***security*** and ***cybersecurity*** are used interchangeably. It is presumed that the term ***security*** is being used in reference to ***cybersecurity*** and not ***physical security***.

Audience

The audience of this document is the cybersecurity practitioner who will be conducting the cybersecurity threat model analysis.

Completeness of Output

Since threat modeling is an as-is analysis, it is critical to ensure that the information gathered is as accurate and complete as possible. As with any cybersecurity assessment, it is not the place of the cybersecurity SME to make assumptions on the part of engineering. All information should be sourced from and confirmed by the owner of the element under consideration.

When information is not available for either a given section of the template or parts thereof, this should be noted. Major omissions should be recorded in the cybersecurity risk register.

Disposition of Output

Once completed, the generated output should be managed in the organization's document management system (DMS) as a document of record.

Entry Criteria

This document assumes that the reader understands the purpose of cybersecurity threat modeling. Further, that the reader has read and understood the AVCDL **Threat Modeling Report** secondary document.

Prerequisites – Threat Modeling SME

Qualifications

It is required that the threat modeling SME is both a qualified and trained security architect (shown above on title page as **Owner**) as defined by the **NIST NCWF** role SP-ARC-002 and detailed in section **12.7 Security Architect** of the AVCDL primary document [\[1\]](#).

Knowledge

It is required that the threat modeling SME understands the purpose of cybersecurity threat modeling.

Background Information

It is required that the threat modeling SME has read and understands the AVCDL **Attack Surface Analysis Report** [\[6\]](#), **Threat Modeling Report**, and **Security Requirements Taxonomy** [\[3\]](#) secondary documents. Additionally, that the cybersecurity SME has taken training relevant to this activity.

Prerequisites – Input Materials

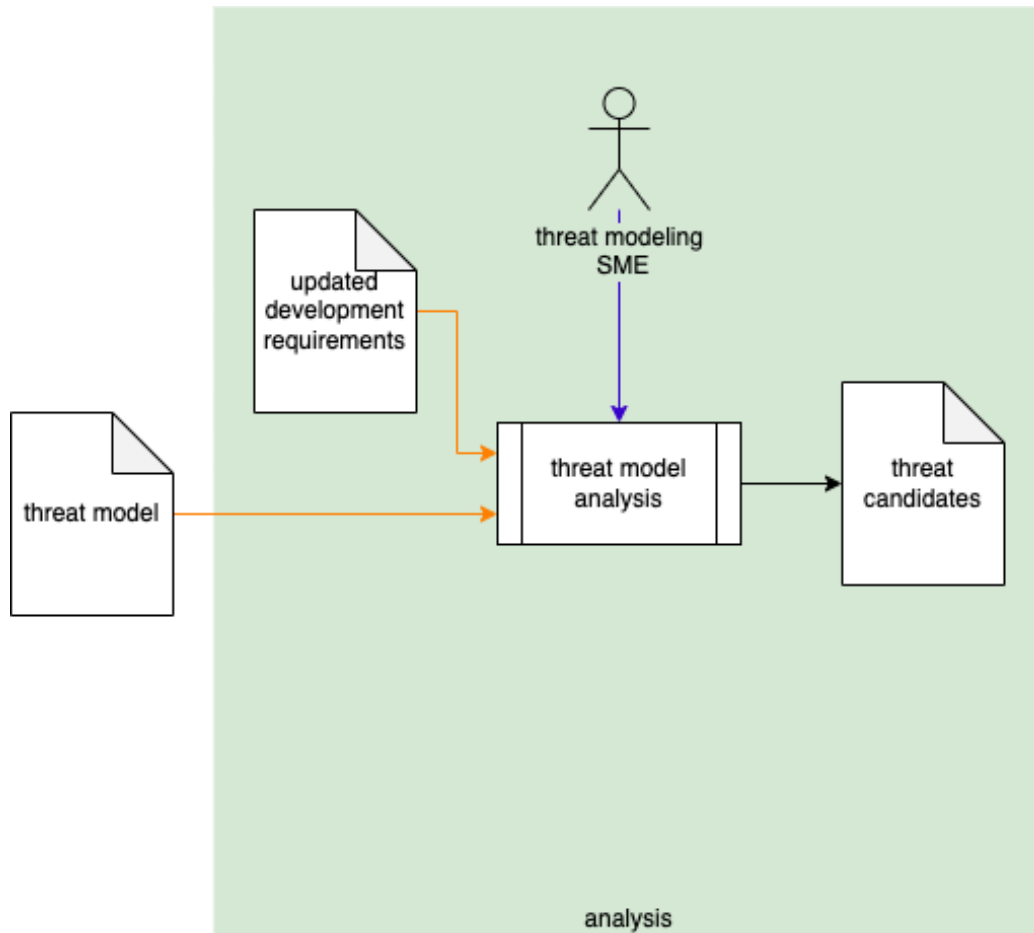
It is required that the threat model for the element under consideration, created in the threat model creation activity, be available.

It is also required that the functional and cybersecurity requirements for the element under consideration be available.

Note: The relationship between functional and cybersecurity requirements is covered in **Product-level Security Requirements** [\[9\]](#) AVCDL secondary document.

Analysis Activity

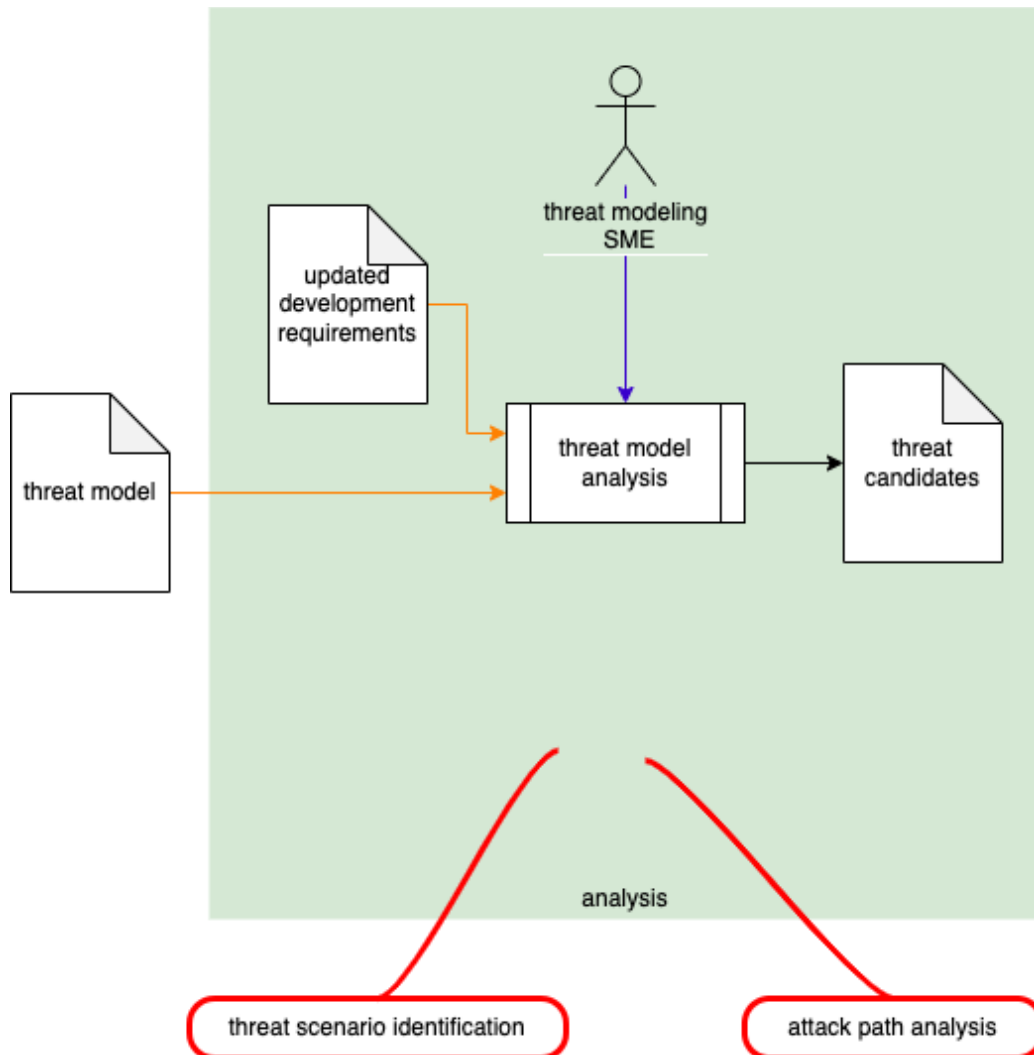
The workflow diagram for the analysis activity of the **Threat Modeling Report** is shown below.



Using the **threat model**, the threat modeling SME analyzes the model with the **updated development requirements** (generated during the **Product-level Security Requirements** process) as a basis to create a set of **threat candidates**.

Theory

The AVCDL **Understanding TARA in an AVCDL Context** ^[5] elaboration document notes that the **analysis** activity equates to the **threat scenario identification** and **attack path analysis** activities of various standards. This is shown in the following diagram. This is the fundamental task of model analysis.



Scope

When performing threat model analysis, it is essential to limit the scope to that of the element under consideration in the context of the element's threat model. As a reminder, the goal of the threat modeling exercise is to establish that appropriate controls are in place to ensure the cybersecurity posture of the element, not other elements which connect to it. When properly created, the threat models of multiple interacting elements will require no modification if composed into a larger abstraction.

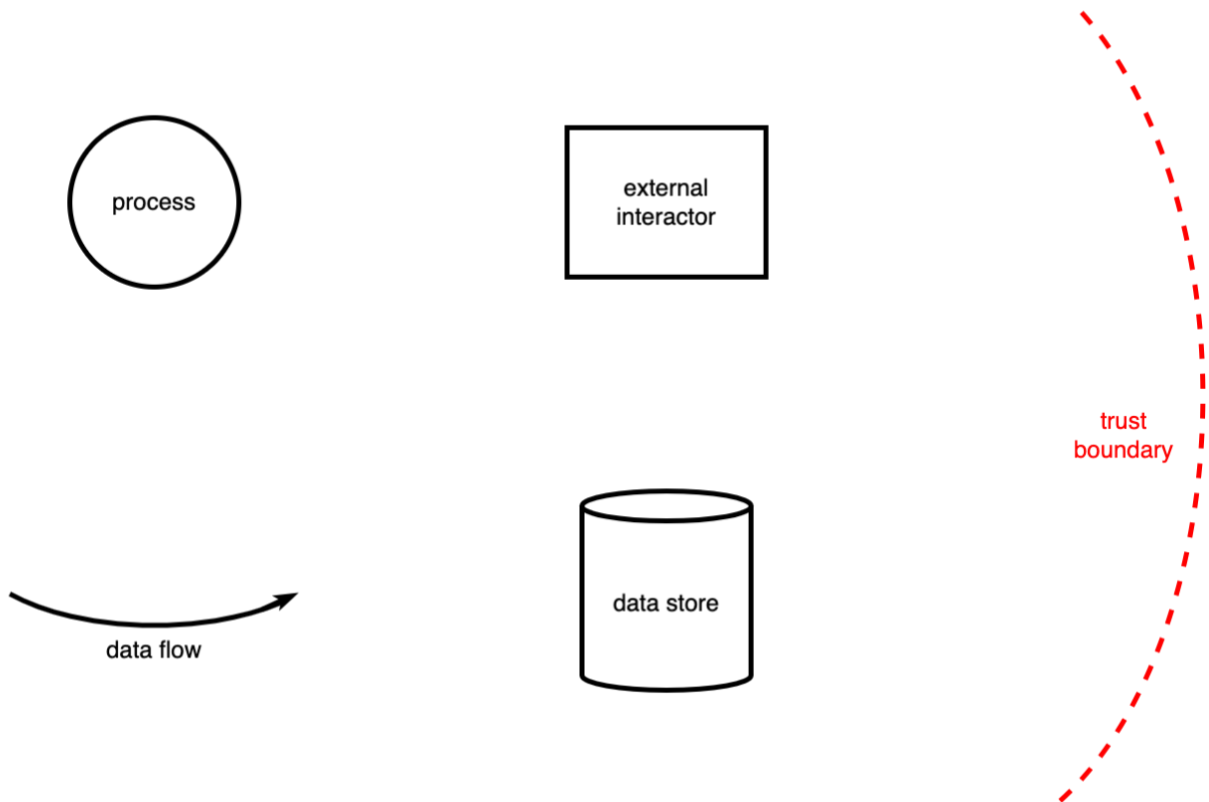
Note: It is important to not treat the threat model analysis as an opportunity to update the threat model. Discrepancies in the model should be addressed as feedback from the triage activity.

Goal

The goal of threat modeling is the establishment of a set of controls necessary to ensure that data crossing a threat boundary can do so securely. Threat modeling cannot assess whether behaviors within individual processes are correct.

Data Flow Diagram Entities

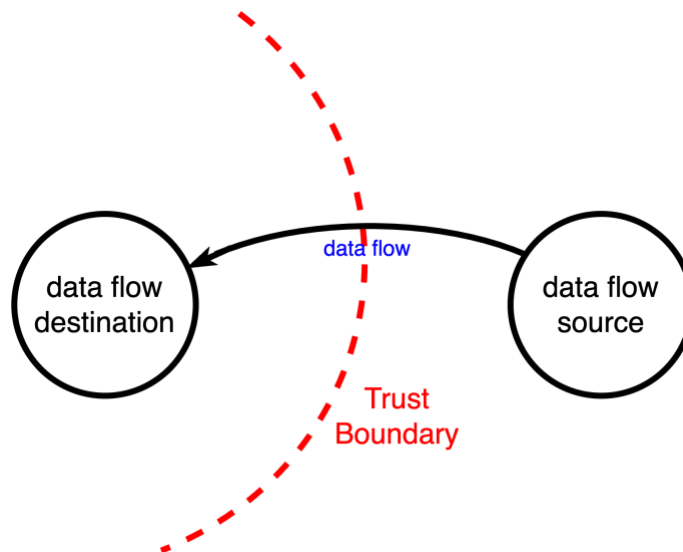
The DFD entities and their attributes are covered in detail in the AVCDL **Threat Modeling Report – Model Creation** [\[7\]](#) procedure. To review, these are **resources**, **processes**, **interactors**, **boundaries**, and **data flows**. Their symbology is shown below.



Methodology

Fundamental Approach

The fundamental approach to threat model analysis based on DFDs can be explained using the following diagram taken from the AVCDL **Threat Modeling Overview** ^[8] video.



Note: The choice of process entities for the **data flow source** and **destination** in the above diagram is arbitrary, and intended to be illustrative, not definitive.

For each **data flow** crossing a **trust boundary**, the attributes of the data flow's **source** and **destination** are evaluated against all cybersecurity requirements applicable to the element under consideration.

Note: Because of its basis in data flow analysis, threat modeling cannot reason against all cybersecurity requirements. This is not a deficiency of threat modeling, but rather a reality that emphasizes the necessity of having multiple activities to ensure a sound cybersecurity posture.

Identification of Applicable Requirements

As noted previously, not all cybersecurity requirements can be reasoned on by the threat modeling analysis activity. If the set of requirements comes from a global catalog, such as the AVCDL **cybersecurity requirements per taxonomy** ^[10], threat model analysis-applicable requirements can easily be identified once. In cases where cybersecurity macro requirements have been created atop a global catalog, it may be necessary to undertake applicability identification.

Note: Although they simplify the requirements process, macro requirements complicate threat modeling and other downstream cybersecurity processes. This is because, unlike the requirements from the global catalog, macro requirements are not uniquely testable.

Order of Analysis

Given the likely number of DFDs associated with the element under consideration, it is important to conduct the analysis so that the number of passes over the various data flows is minimized. The recommended order of analysis is:

1. OS-centric DFDs
2. Third party-centric DFDs
3. Element-centric DFDs

The reasoning behind this order is first that there should exist a stable relationship between the OS and element under consideration. At a certain point, the OS-centric DFD analysis should be complete enough to share among multiple elements.

Note: The mechanism for DFD sharing between elements is not addressed in this material.

Secondly, generally speaking third party processes will be supporting the element. The implication of this is that the third party processes will be assigned a higher level of trust than external entities.

OS-centric DFDs

As noted in the AVCDL **Threat Modeling Report – Model Creation** procedure, the operating system is comprised of set of components. These include:

- Filesystem
- Network manager
- Process manager
- IPC manager
- Device driver
- Service (daemon)
- Memory manager

From the standpoint of DFD analysis, the operating system is treated as being at the highest level of trust with respect to the element. This being the case, there will be few, if any, issues seen here. Analysis of the OS-centric DFDs is more an exercise in confirming that the lowest level of interaction has been properly accounted for.

Note: It is not intent of the element model analysis activity to assess the cybersecurity posture of the operating system. This should be done as a separate exercise.

Third party-centric DFDs

Third party and, by extension, open source entities with which the element interacts tend to present the greatest source of threats due to their not being maintained directly. Typical entities include:

- Database manager
- Network protocol
- Device driver
- Service (daemon)
- Process

From the standpoint of cybersecurity, it is useful to treat both third party and open source components as being untrusted. This puts them at the same level of trust as interactors.

Like operating system entities, third party entities tend to be used as supporting abstractions. Unlike operation system entities, because they are untrusted, they can be a substantial source of threat candidates. This is not because of issues within these entities, but rather because the element has not been designed in a way which considers them to be untrusted.

Note: Failure on the part of the element design to consider third party and open source entities as untrusted is especially problematic when these entities are responsible for cybersecurity-relevant tasks, such as cryptography.

Element-centric DFDs

Because of the intrinsic trust between entities within the element, it presents the greatest source of threat candidates. Element entities include:

- Device driver
- Service (daemon)
- Process

Unlike OS and third party-centric DFDs, element-centric DFDs typically take the form of specific workflows. Exceptions to this are interactions with element driver entities and services. Both of these are single-use case in nature and are treated like the non-element-centric entities. These two entity types should be addressed first as they should present fairly easy analysis.

What remains should be a set of element-centric DFDs focused on process entities collected into distinct workflows.

Note: It is just as important to understand the trust relationships between the element and any open source or third-party processes as it is to do so with the operating system processes.

Replication of Threat Candidates

It is inevitable that the analysis of the DFDs created for the element under consideration will result in replicated results. This is due to the various data flow triplets (source, data flow, destination) being reused in multiple workflows. When this is the case, it is important to deduplicate these in order to avoid the problems that duplicate issue reporting creates.

An example of this might be workflows in which logging is done.

Threat Model Analysis Template

The element cybersecurity requirements catalog may be documented using the **AVCDL threat modeling analysis template** Microsoft Excel workbook [\[4\]](#).

Note: Other forms of documentation are permissible so long as they provide the information laid out in this document.

There are five sheets in the workbook. They are:

- [Cover sheet](#)
- [Revision history](#)
- [Reference documents](#)
- [Issues](#)
- [Legend](#)

These will be addressed in turn.

Duplication of Rows in the Various Sheets

When there is the need to add rows to the various sheets of the workbook, be sure to duplicate an existing row. This is because validation checks are attached to some of the cells which also enables the use of dropdown lists.

Cover Sheet

The **cover sheet** of the workbook is shown below:

Threat Modeling - Analysis								
Element Name	Element Name							
Element Scope	Element Scope							
Vendor Name	Vendor Name							
Threat Modeling SME	Threat Modeling SME							
Date	27-Aug-2000							
Model Revision	1							

Fields to be completed are shown in **red**.

Element Name

The **element name** is the element being modeled.

Element Scope

The scope of the element is left to the discretion of the customer. Examples of element scopes include system, sub-system, component, component software (non-OS), and component OS.

Note: In this context, **the customer** refers to the entity requiring the activity.

Vendor Name

This is the name of the vendor responsible for the element being modeled.

Threat Modeling SME

This is the threat modeling subject matter expert creating the threat model.

Date

This is the date when the element's threat model was created or updated. The date should be updated whenever the model is updated.

Revision

This is the revision number of the document. The revision number is a monotonic and increasing integer, starting at 1. It should be incremented every time the document is updated.

Revision History

The **revision history** sheet of the workbook is shown below:

Revision History		
Revision	Author	Description
1		initial revision

Revision

The **revision** corresponds to that listed on the cover sheet.

Author

The **author** corresponds to the threat modeling SME listed on the cover sheet.

Description

This is a brief description of changes made to the threat model analysis since it was last updated.

Reference Documents

Note: These references are those necessary for the creation of the element's threat model.

Note: References to the element's threat model and cybersecurity requirements documents should be included.

The **references** sheet of the workbook is shown below:

Reference Documents		
Name	Description	Location

Name

This is the name of the document being referenced.

Description

This is a brief description of the document being referenced.

Location

This is the location of the document being referenced. It may be a physical location or a URL.

Issues

The **issues** sheet of the workbook is shown below:

Identified Issues				
ID	data flow ID	requirement ID	issue	notes

ID

This is the unique element threat model issue ID.

Data flow ID

This is the element threat model data flow ID.

Requirement ID

This is the relevant cybersecurity requirement ID.

Issue

This is the identified issue.

Note: It is recommended that the statement of the issue be minimal and in the form of the aspect(s) of the requirement not fulfilled by the attributes of the entities.

Notes

This is a general notes field.

Legend

Note: This template does not use the legend sheet. It should not be deleted however, as the templates version number is on this sheet.

Exit Criteria

This procedure is considered complete once the generated output has been entered into the organization's DMS as a document of record.

Note: The processes and procedures for entering documents into the DMS, or the updating thereof, are outside the scope of this document.

References

1. **AVCDL** (AVCDL primary document)
2. **Threat Modeling Report** (AVCDL secondary document)
3. Security Requirements Taxonomy (AVCDL secondary document)
4. AVCDL threat modeling analysis template (AVCDL template)
5. Understanding TARA in an AVCDL context (AVCDL elaboration document)
6. Attack Surface Analysis Report (AVCDL secondary document)
7. Threat Modeling Report – Model Creation (AVCDL tertiary document)
8. Threat Modeling Overview (AVCDL video)
9. Product-level Security Requirements (AVCDL secondary document)
10. cybersecurity requirements per taxonomy (AVCDL working material)